

Meridian Technologies

Information Security Policy — Version 2.4

Effective Date: January 1, 2024 | Owner: Chief Information Security Officer

1. Purpose and Scope

This policy establishes the information security requirements for all employees, contractors, and third-party vendors who access Meridian Technologies systems, networks, or data. It applies to all company-owned and personal devices used for business purposes.

2. Password Policy

All user accounts must comply with the following password requirements:

- Minimum password length: 14 characters.
- Passwords must include at least one uppercase letter, one lowercase letter, one digit, and one special character.
- Passwords must be changed every 90 days.
- The last 12 passwords may not be reused.
- Accounts are locked after 5 consecutive failed login attempts. Locked accounts must be unlocked by the IT Help Desk.

3. Multi-Factor Authentication (MFA)

Multi-factor authentication is mandatory for all employees, contractors, and vendors without exception. MFA is enforced at the identity provider level using Okta. Hardware security keys (FIDO2) are required for all privileged administrator accounts. Time-based one-time passwords (TOTP) via an authenticator app are acceptable for standard user accounts.

4. Data Classification

Meridian Technologies classifies all data into four levels:

- Public: Information approved for unrestricted external distribution.
- Internal: General business information not intended for public release.
- Confidential: Sensitive business data including contracts, financials, and personnel records. Access is restricted to authorized personnel.

- Restricted: Highly sensitive data including cryptographic keys, customer PII, and regulated health information. Access requires executive approval and is logged.

5. Acceptable Use and Personal Devices (BYOD)

Employees may use personal devices to access company email and the employee portal only. Personal devices must have the company Mobile Device Management (MDM) profile installed and must run an OS version supported by the vendor. Accessing Confidential or Restricted data from a personal device is prohibited. The company reserves the right to remotely wipe the corporate profile from any enrolled device.

6. Security Awareness Training

All employees and contractors must complete the mandatory security awareness training program. Training must be completed within 30 days of onboarding and renewed annually thereafter. Phishing simulation exercises are conducted quarterly. Employees who fail two consecutive phishing simulations are required to complete an additional remedial training module within 14 days.

7. Incident Response and Log Retention

All security incidents must be reported to the Security Operations Center (SOC) within 2 hours of detection. The SOC will triage, contain, and remediate incidents in accordance with the Incident Response Playbook. Security event logs are retained for a minimum of 24 months. Logs for Restricted data access events are retained for 7 years to comply with regulatory requirements.

8. Enforcement

Violations of this policy may result in disciplinary action up to and including termination of employment or contract. Suspected criminal activity will be reported to appropriate law enforcement agencies. Policy exceptions require written approval from the CISO and must be reviewed annually.